

Web Application Vulnerability Scanning with OWASP ZAP

This lab demonstrates **dynamic application security testing (DAST)** using OWASP ZAP against a deliberately vulnerable web application.

Objective

- Perform automated vulnerability scanning.
- Identify common vulnerabilities (XSS, SQL Injection, etc.).
- Interpret alerts and generate a report.

Lab Environment Setup

Step 1: Install OWASP ZAP on Windows

1. Go to the official site
<https://www.zaproxy.org/download/>
2. Download the **Windows Installer**
3. Run the installer and follow the setup.

After installation open:

OWASP ZAP

Step 2: Install Node.js

Juice Shop runs using **Node.js**.

1. Go to
<https://nodejs.org>
 2. Download **LTS version**
 3. Install with default settings.
-

Step 3: Install OWASP Juice Shop

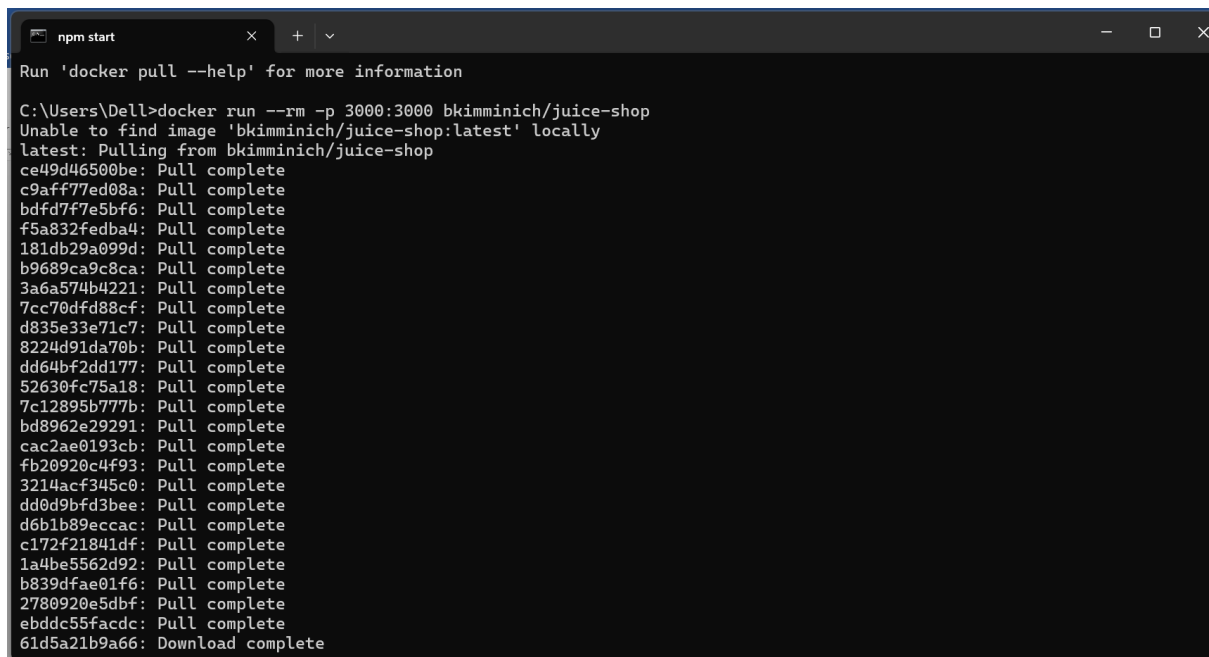
Open **Command Prompt**.

Run:

```
docker run --rm -p 3000:3000 bkimminich/juice-shop
```

OR

```
docker run -d -p 3000:3000 bkimminich/juice-shop
```

A terminal window titled 'npm start' with standard window controls. It shows the command 'docker run --rm -p 3000:3000 bkimminich/juice-shop' being executed. The output indicates that the image 'bkimminich/juice-shop:latest' was not found locally and is being pulled from Docker Hub. A list of 25 layers is shown, each with a pull progress bar and the status 'Pull complete'. The final layer, '61d5a21b9a66', is marked as 'Download complete'.

```
Run 'docker pull --help' for more information

C:\Users\Dell>docker run --rm -p 3000:3000 bkimminich/juice-shop
Unable to find image 'bkimminich/juice-shop:latest' locally
latest: Pulling from bkimminich/juice-shop
ce49d46500be: Pull complete
c9aff77ed08a: Pull complete
bdfd7f7e5bf6: Pull complete
f5a832fedba4: Pull complete
181db29a099d: Pull complete
b9689ca9c8ca: Pull complete
3a6a574b4221: Pull complete
7cc70dfd88cf: Pull complete
d835e33e71c7: Pull complete
8224d91da70b: Pull complete
dd64bf2dd177: Pull complete
52630fc75a18: Pull complete
7c12895b777b: Pull complete
bd8962e29291: Pull complete
cac2ae0193cb: Pull complete
fb20920c4f93: Pull complete
3214acf345c0: Pull complete
dd0d9bfd3bee: Pull complete
d6b1b89eccac: Pull complete
c172f21841df: Pull complete
1a4be5562d92: Pull complete
b839dfae01f6: Pull complete
2780920e5dbf: Pull complete
ebddc55facdc: Pull complete
61d5a21b9a66: Download complete
```

Go to the folder:

```
cd juice-shop
```

Install dependencies:

```
npm install
```

Start the application:

```
npm start
```

```
npm start
operable program or batch file.
C:\Users\Dell>cd juice-shop
C:\Users\Dell\juice-shop>npm start
> juice-shop@19.2.1 start
> node build/app

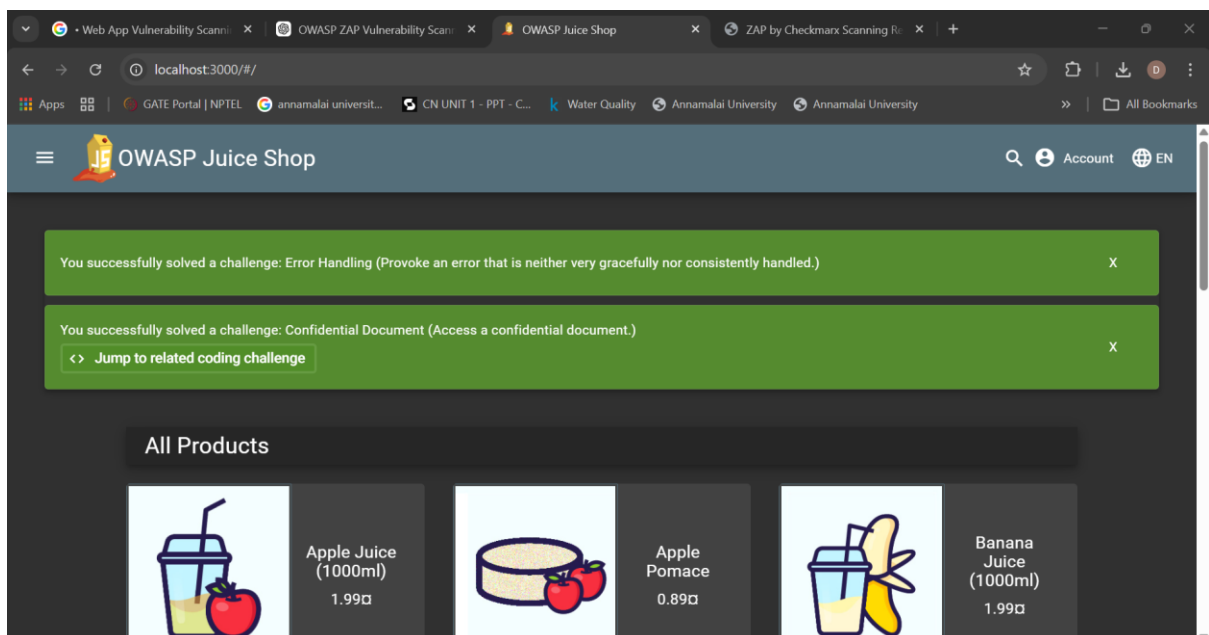
info: Detected Node.js version v24.14.0 (OK)
info: Detected OS win32 (OK)
info: Detected CPU x64 (OK)
info: Configuration default validated (OK)
info: Entity models 20 of 20 are initialized (OK)
info: Required file server.js is present (OK)
info: Required file styles.css is present (OK)
info: Required file index.html is present (OK)
info: Required file polyfills.js is present (OK)
info: Required file main.js is present (OK)
info: Required file matching /^hacking-instructor-.+\.js$/ is present (OK)
info: Port 3000 is available (OK)
info: Chatbot training data botDefaultTrainingData.json validated (OK)
info: Domain https://www.alchemy.com/ is reachable (OK)
info: Server listening on port 3000
Error: Only .md and .pdf files are allowed!
    at verify (C:\Users\Dell\juice-shop\build\routes\fileServer.js:59:18)
    at C:\Users\Dell\juice-shop\build\routes\fileServer.js:43:13
    at Layer.handle [as handle_request] (C:\Users\Dell\juice-shop\node_modules\express\lib\router\layer.js:95:5)
    at trim_prefix (C:\Users\Dell\juice-shop\node_modules\express\lib\router\index.js:328:13)
    at C:\Users\Dell\juice-shop\node_modules\express\lib\router\index.js:286:9
```

Step 4: Open Juice Shop

Open browser and go to:

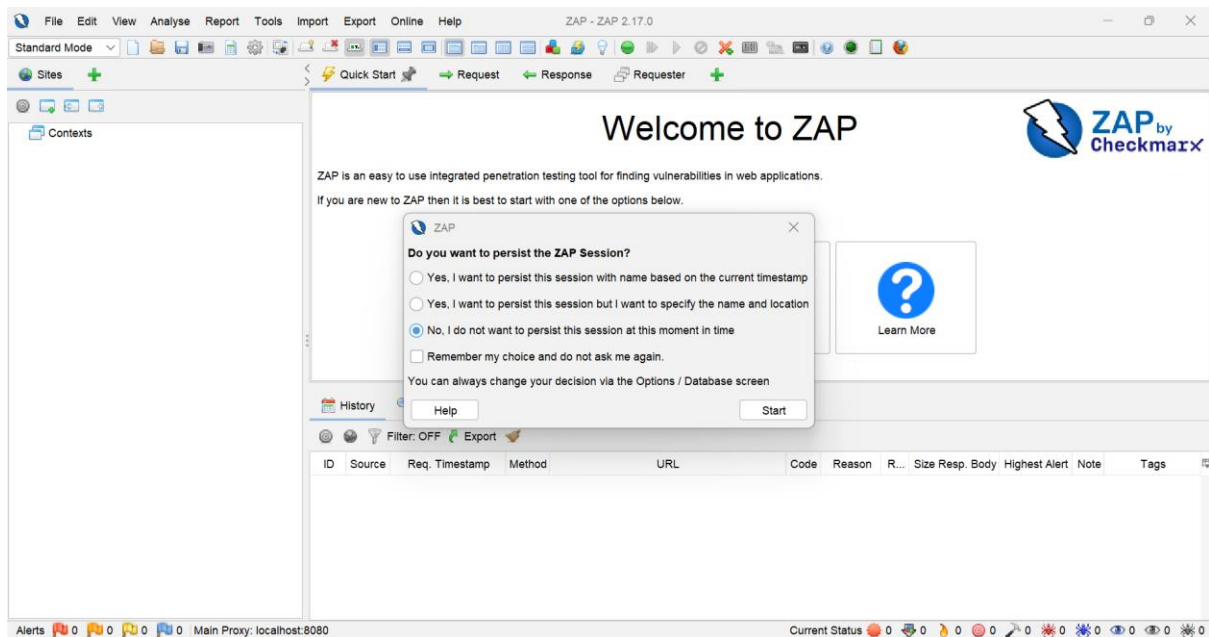
http://localhost:3000

You will see the **Juice Shop** web application.



Step 5: Start OWASP ZAP

Open **OWASP ZAP**.



When prompted choose:

No, I do not want to persist this session

Click **Start**.

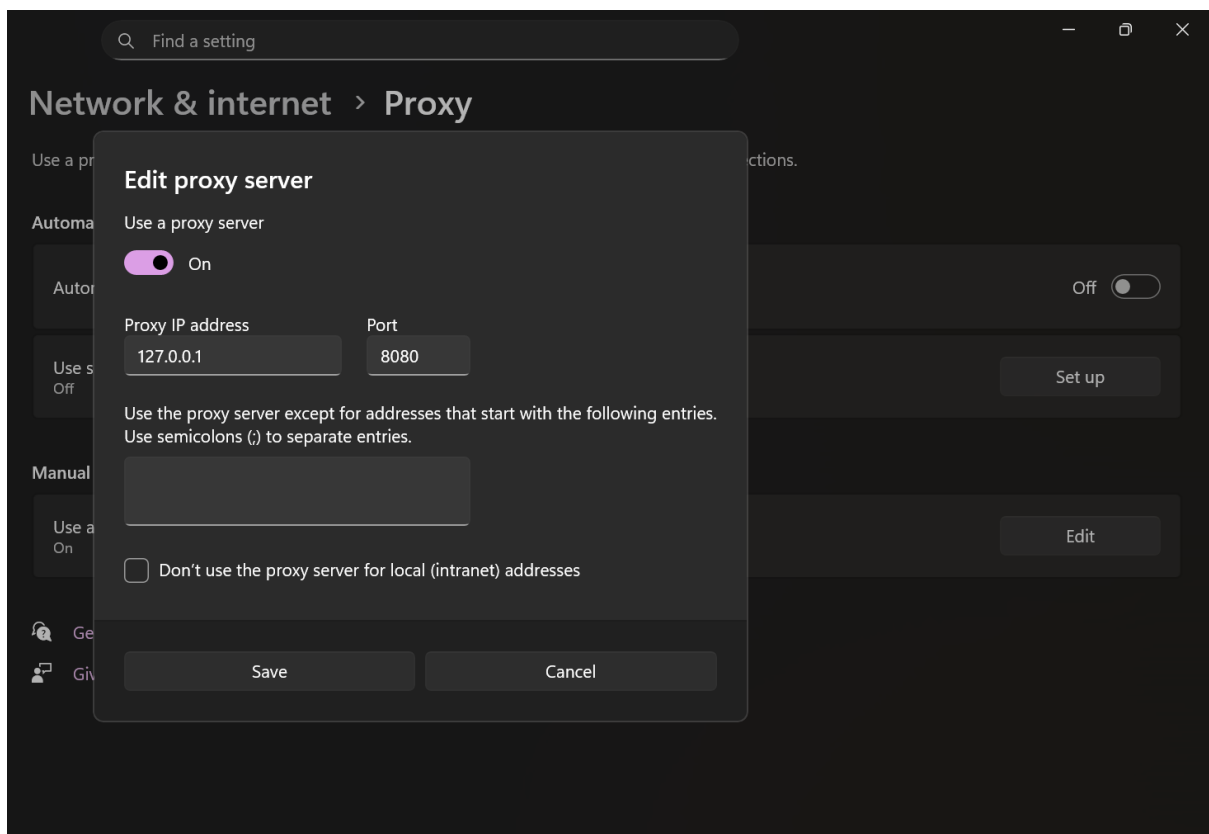
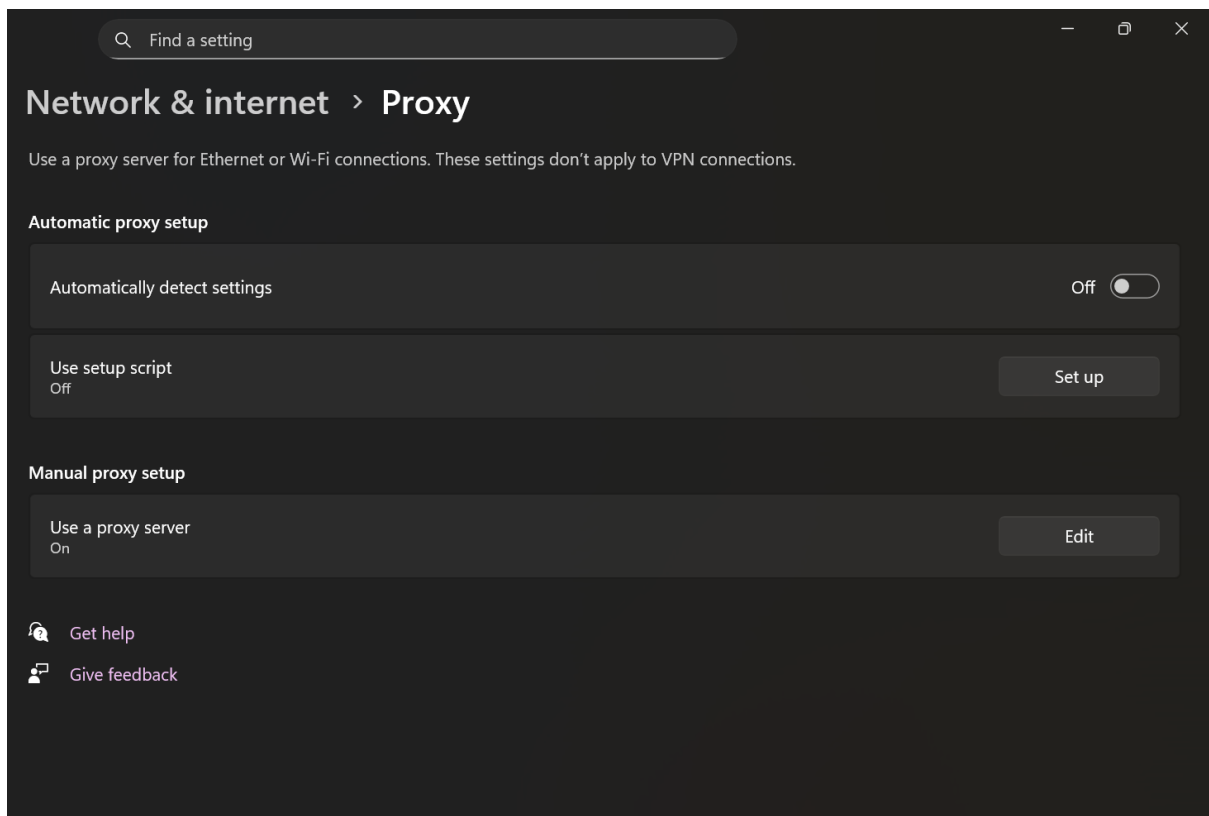
Click on automated scan

Step 6: Configure Browser Proxy

In browser proxy settings configure:

HTTP Proxy : 127.0.0.1

Port : 8080



Now browser traffic passes through **ZAP**.

Step 7: Confirm Connection

Open:

`http://localhost:3000`

In ZAP Sites panel you will see:

`http://localhost:3000`

Step 8: Perform Spider Scan

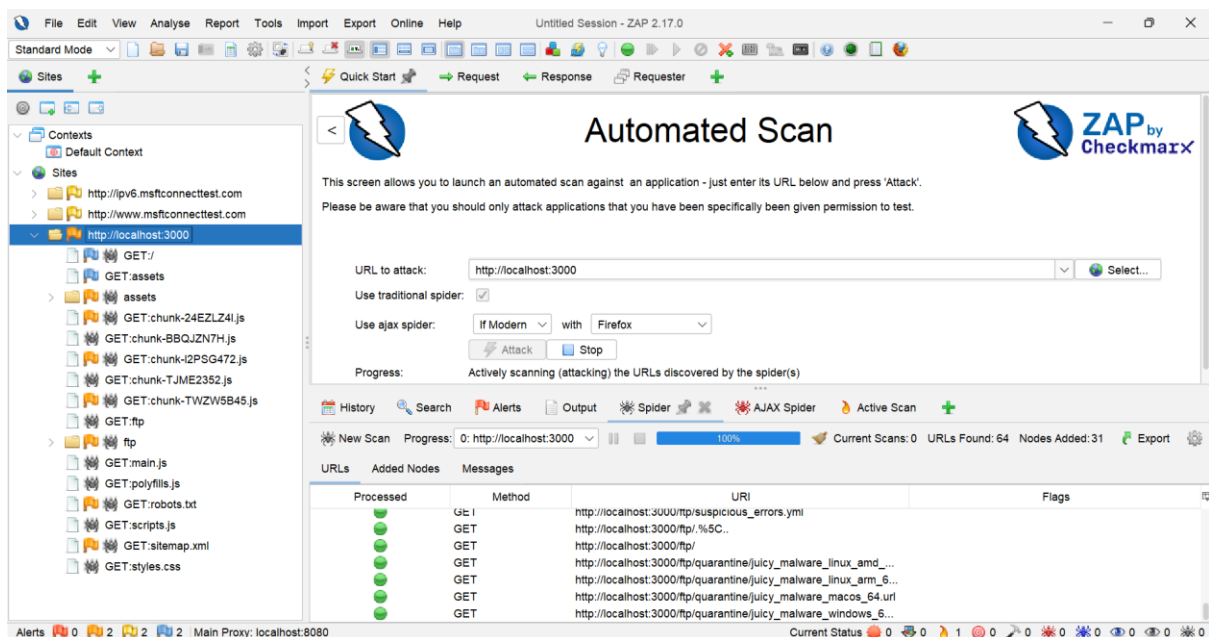
Right-click:

`http://localhost:3000`

Select:

Attack → Spider

Click **Start Scan**.



ZAP will discover all pages.

Step 9: Perform Active Scan

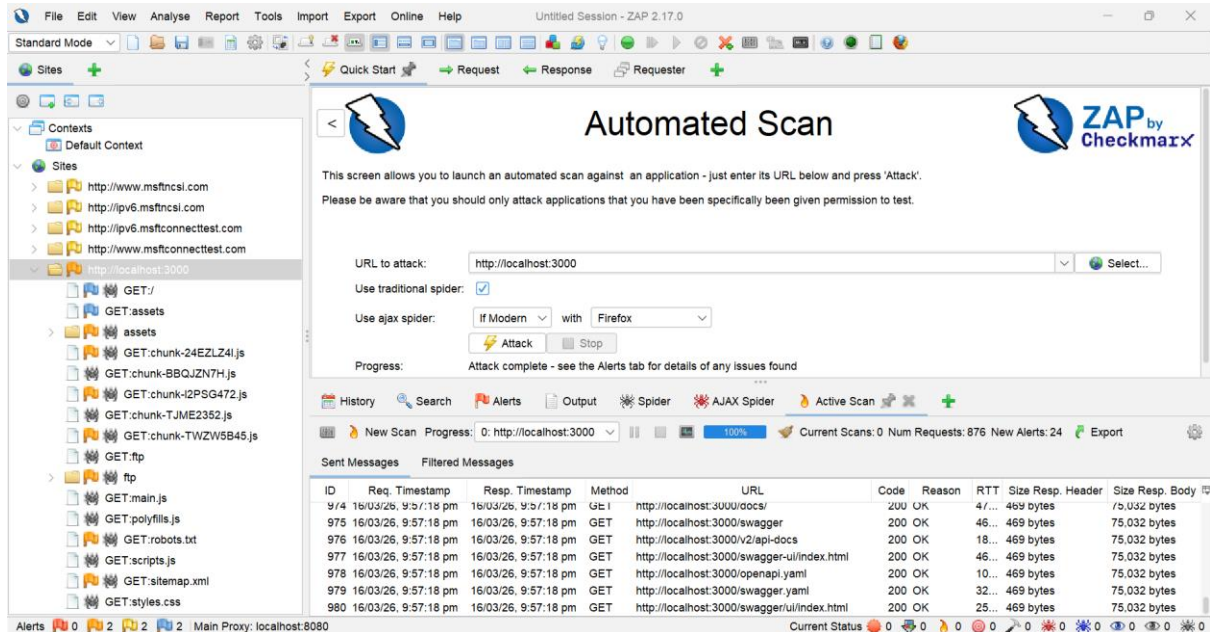
Right-click again:

`http://localhost:3000`

Select:

Attack → Active Scan

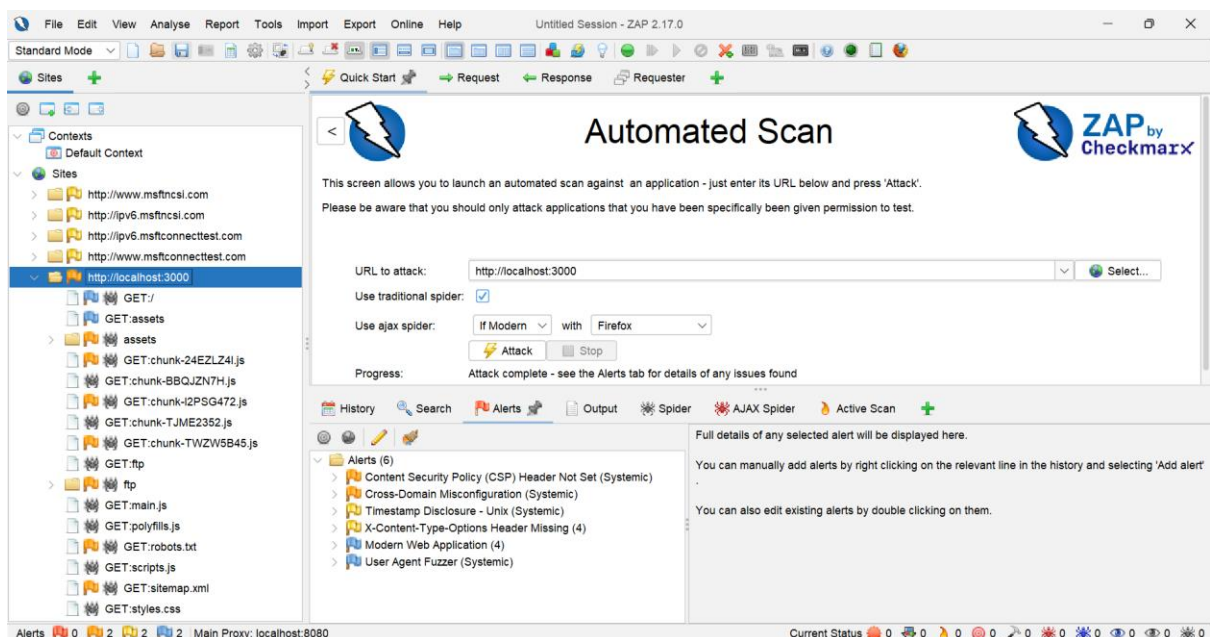
Click **Start Scan**.



ZAP will test vulnerabilities.

Step 10: Analyze Vulnerabilities

Open the **Alerts** tab.



You may see vulnerabilities like:

- Cross Site Scripting
- Missing security headers
- Cookie security issues
- Information disclosure

Analysing Results

Step 11: View Alerts

Go to:

Alerts Tab

Alerts are categorized by risk:

Risk Level	Meaning
High	Critical vulnerability
Medium	Exploitable issue
Low	Minor issue
Informational	No direct risk

Click any alert to view:

- Description
- Evidence
- Attack payload used
- Suggested remediation

Step 12: Export Scan Report

1. Go to **Report**
2. Choose format:
 - HTML
 - PDF
 - XML
3. Select:
 - Risk levels
 - Confidence level
4. Generate report

Save file.

-

Result

The vulnerable web application was scanned using **OWASP ZAP**, and multiple vulnerabilities were identified in **OWASP Juice Shop**.